

NARRATIVA EXPLICATIVA CON TONO IRÓNICO-LITERARIO

Sobre la Encuesta Integral de Ciberseguridad y Gobernanza IA

Una Reflexión Propositiva y Constructiva

Versión: 1.0

Fecha: Enero 2026

Tono: Irónico, literario, propositivo, alegre y constructivo

PREFACIO: ENTRE LA SEGURIDAD Y EL CAOS (O, MÁS BIEN, ENTRE LA NEGACIÓN Y LA ACEPTACIÓN)

Si hay algo que distingue a las organizaciones modernas—esas ciudades digitales que construimos con heroísmo de hormiguero colectivo—es que **sabemos exactamente qué no sabemos**.

Sabemos que no sabemos si nuestros sistemas de IA son justos. Sabemos que ignoramos si nuestros pentests son suficientemente creativos. Sabemos, con una certeza casi cómica, que no tenemos idea de cuántos modelos viven en nuestras infraestructuras, ni qué hacen a las 3 de la mañana cuando todos dormimos.

La encuesta que le presentamos aquí no es—permítase la frivolidad—una herramienta para resolver todos esos "no saberes". Es algo más modesto y, paradójicamente, más ambicioso: es una **invitación a la honestidad institucionalizada**. Es un espejo que dice: "Aquí está tu reflejo; no es perfecto, pero al menos es tuyo."

ACTO I: LA ILUSIÓN DE LA CONFIANZA CIEGA

Escena 1: El Síndrome del "Confiamos en el Firewall"

En la mayoría de organizaciones, el modelo de seguridad se estructura así:

```
Director General ✓ Confiamos en cosas
    ↓ (porque son cosas
IT Director      confusas y
    ↓            lejanas)
CISO/CTO ✓ Monitoreamos
    ↓ (cuando lo
Security Team    recordamos)
    ↓
[FIREWALL] ✓ Protege todo
    ↓ (a menos que
Internet        los malos sean
    ↓          creativos,
[ATTACK]        lo cual siempre
                lo son)
```

En esta pirámide, la confianza fluye hacia arriba—hacia la ilusión consoladora de que "está todo controlado"—mientras el riesgo fluye hacia abajo, donde nadie lo ve hasta que es demasiado tarde.

La ironía exquisita: Cuando preguntas a la mayoría de CISOs "¿Miden riesgo de IA con rigor cuantitativo?", la respuesta es una risotada irónica seguida de: "¿Cuantitativo? Hermano, si apenas sabemos cuántos modelos IA tenemos."

Escena 2: El Ritual del Cumplimiento Sin Acción

Existe una ceremonia sagrada en el mundo corporativo: **el Assessment que Se Olvida.**

Sucede así:

1. Semana 1: "¡Vamos a hacer una evaluación integral de seguridad!"
2. Entusiasmo general
3. Consultores contratados
4. Calendarios de reuniones enviados
5. Semanas 2-4: Evaluación exhaustiva
6. 40 horas de entrevistas
7. Documentos compilados
8. Conversaciones profundas sobre riesgos
9. Semana 5: Reporte presentado
10. Dashboard bonito con gráficos en rojo
11. Gasps del Board
12. "Haremos algo al respecto"
13. Semana 6 en adelante: El reporte reposa en el repositorio institucional
14. Llamado ocasionalmente en auditorías: "Sí, tenemos plan de remediación"
15. El plan está documentado... en alguna carpeta compartida
16. Los KPIs nunca se activan realmente

Calendarios de reuniones enviados

Semanas 2-4: Evaluación exhaustiva

Conversaciones profundas sobre riesgos

Semana 5: Reporte presentado

"Haremos algo al respecto"

Semana 6 en adelante: El reporte reposa en el repositorio institucional

¿El síntoma de esta dolencia?

Falta de **propiedad clara**, falta de **cadencia de revisión**, falta de **consecuencias ejecutivas** si los gaps no se remedian.

Es el equivalente organizacional de prometer un "nuevo comienzo el lunes" a las 11:59 del domingo.

ACTO II: LA ENTRADA TRIUNFAL DE CINCO DIMENSIONES

Aquí Entra Nuestro Héroe: La Encuesta de Cinco Módulos

Pero espere. Hay una buena noticia. Existe un camino diferente—no porque sea fácil, sino porque es *necesario*.

La encuesta que hemos diseñado aborda **cinco dimensiones que son el corazón (aunque también pudieran ser el riñón, el páncreas, quien sabe) de cualquier postura de ciberseguridad moderna:**

Módulo 1: Gobernanza y Riesgo (GOVERN)

La Metáfora del Gobierno

Un sistema de gobierno sin constitución es una turba con megáfonos. De manera análoga, una organización sin gobernanza de IA es un rebaño de modelos vagando sin brújula.

¿Qué preguntamos?

- ¿Existe política formal? (Nivel 1: No. Nivel 5: Sí, y se auto-actualiza según cambios regulatorios)
- ¿Quién es responsable? (Nivel 1: "No está claro." Nivel 5: "Aquí está el RACI, auditado mensualmente")
- ¿Existe comité de gobernanza? (Nivel 1: "¿Comité?" Nivel 5: "Sí, con representación interdisciplinaria y actas")

La belleza de GOVERN es que es el anclaje: Sin gobernanza clara, todo lo demás es castillo de naipes. Con gobernanza robusta, el resto es scaffolding constructivo.

Módulo 2: Mapeo de Contexto e Impacto (MAP)

La Metáfora del Cartógrafo Responsable

Imagínese una expedición sin mapa. No es aventura romántica; es caos con equipos caros.

Analogía: Los sistemas de IA que deployamos sin entender su contexto (a quién afectan, qué podrían salir mal, qué alternativas existen) son exactamente eso: caos con GPUs costosas.

¿Qué preguntamos?

- ¿Documentan propósito + beneficiarios + impactados? (Nivel 1: "Es un modelo." Nivel 5: "Aquí está el stakeholder mapping completo")
- ¿Evaluaron alternativas no-IA? (Nivel 1: "¿Alternativas?" Nivel 5: "Sí, aquí está el análisis costo-beneficio")
- ¿Documentan riesgos específicos del sistema? (Nivel 1: No. Nivel 5: Sí, con Impact×Likelihood matrix)

La genialidad de MAP es que es preventivo: Si entienden el contexto de verdad, muchos problemas desaparecen antes de nacer.

Módulo 3: Medición y Métricas (MEASURE)

La Metáfora del Científico Riguroso

"Lo que no se mide, no se gestiona. Lo que no se gestiona, explota generalmente a las 3 de la mañana en producción."

MEASURE es donde la magia ocurre. Las siete características de trustworthiness (Valid, Safe, Secure, Accountable, Explainable, Privacy-Enhanced, Fair) **no son conceptos poéticos:** son métricas cuantificables.

¿Qué preguntamos?

- ¿Miden accuracy (p.ej., ≥95%)? (Nivel 1: No. Nivel 5: Sí, desagregado por demografía, con alertas si baja)
- ¿Miden bias (p.ej., demographic parity < 5%)? (Nivel 1: "¿Bias?" Nivel 5: "Audit trimestral, automático")
- ¿Miden seguridad (MTTD < 1h)? (Nivel 1: No. Nivel 5: Sí, dashboard en tiempo real)

El poder de MEASURE es que convierte vagas aspiraciones en hechos verificables.

Módulo 4: Vulnerabilidades y Penetration Testing

La Metáfora del Sabueso Perseverante

Si GOVERN es el sistema inmunológico político de la organización, y MAP es el sistema nervioso sensorial, entonces **Vulnerabilidades y Pentesting son el sistema inmunológico técnico.**

Pentesting es—literalmente—pagar a personas inteligentes para que intenten romper tus sistemas. Si no lo hacen los buenos (los tuyos), lo harán los malos (los otros).

¿Qué preguntamos?

- ¿Hacen penetration testing? (Nivel 1: No. Nivel 5: Continuo, integrado en CI/CD, rojo vs. azul teams)
- ¿Incluyen ataques IA-específicos? (Nivel 1: "¿Ataques IA?" Nivel 5: "Sí, data poisoning, prompt injection, model extraction")
- ¿Rastrear hallazgos y remedian rápido? (Nivel 1: "Se olvidan." Nivel 5: "Dashboard con SLA por criticidad")

La sabiduría de Pentesting es que abraza el conflicto constructivo:** te atacan para hacerte más fuerte.

Módulo 5: SIEM y Capacitación de Empleados

La Metáfora del Vigía Insomne y la Multitud Educada

SIEM (Security Information & Event Management) es tu vigía nocturno: mira toda la infraestructura, 24/7, detecta anomalías que los humanos se perderían.

Capacitación es la educación de tu multitud: el 90% de brechas comienzan con un click de phishing. Un empleado bien entrenado es tu mejor firewall.

¿Qué preguntamos?

- ¿Tienen SIEM centralizado con machine learning? (Nivel 1: No. Nivel 5: Sí, con anomaly detection inteligente)
- ¿Realizan capacitación mandatoria de seguridad? (Nivel 1: No. Nivel 5: Continuo, personalizado, gamificado)
- ¿Miden efectividad más allá de completion rates? (Nivel 1: No. Nivel 5: Sí, behavioral metrics, click rates trending)

El romance de SIEM + Capacitación es que multiplican el efecto: máquinas atentas + humanos vigilantes = fortaleza exponencial.

ACTO III: LA ANATOMÍA DE LA ESCALA DE MADUREZ (O, EL VIAJE DE LA IGNORANCIA A LA OMNISCENCIA RELATIVA)

Los Cinco Niveles: Un Viaje Moral y Técnico

NIVEL 1: Ad-Hoc / Inexistente

└ "Esperamos que funcione"

Característica: Caos controlado (en realidad, solo caos)

Respuesta ante incidente: "¿Qué incidente?"

Frase favorita: "No hemos tenido problema (todavía)"

Futuro probable: Breach masivo, headlines incómodas

NIVEL 2: Incipiente / Repetible

└ "Sabemos que deberíamos hacer algo"

Característica: Procesos informales, inconsistentes

Respuesta ante incidente: "¡Rápido, investigad!"

Frase favorita: "El año que viene hacemos roadmap"

Futuro probable: Crisis evitada por suerte, no por diseño

NIVEL 3: Definido / Estándar

└ "Tenemos procesos. De verdad. Aquí está el documento."

Característica: Estándares documentados, aplicados ampliamente

Respuesta ante incidente: "Activamos playbook, seguimos SLA"

Frase favorita: "Cumplimos regulación"

Futuro probable: Mejora sostenible, si no relajamos la vigilancia

NIVEL 4: Cuantificado / Gestionado

└ "No solo lo hacemos; medimos que lo estamos haciendo bien"

Característica: Datos + métricas + mejora continua

Respuesta ante incidente: "Aquí está RCA, corrección implementada, trending down"

Frase favorita: "Aquí están nuestros KPIs"

Futuro probable: Liderazgo sectorial, benchmark para otros

NIVEL 5: Optimizado / Proactivo

└ "Predicamos lo que va a salir mal y lo evitamos antes de que ocurra"

Característica: Automatización, inteligencia artificial, predicción

Respuesta ante incidente: "Lo detectamos 3 minutos antes de que fuera un problema"

Frase favorita: "¿Problema? Aquí hay 17 mejoras que anticipan ese escenario"

Futuro probable: Contribución activa a estándares globales, orgullo merecido

La Verdad Incómoda: La mayoría de organizaciones españolas están en **Nivel 2-3 en Gobernanza** pero **Nivel 1-2 en Medición de IA**. Es como tener un gobierno y un sistema legal, pero sin estadísticas de delitos. Decorativo, pero poco útil.

ACTO IV: LAS PREGUNTAS INCÓMODAS (O, POR QUÉ LA ENCUESTA TIENE QUE MOLESTAR UN POCO)

Pregunta Incómoda #1: "¿Miden Bias en Modelos de Decisión Crítica?"

La respuesta típica: "Sí, tenemos un modelo de ML que... es justo, ¿no?"

La pregunta de seguimiento (que es donde sucede la incomodidad): "¿Puedo ver el reporte de bias? ¿La métrica específica? ¿Cuándo fue el último audit?"

La respuesta real: Silencio. Luego: "Ese es un proyecto para el próximo trimestre."

¿Por qué es importante? Porque si tu modelo de credit scoring tiene 10% más falsos positivos para mujeres, estás codificando discriminación en máquina. No es accidental; es replicación digital de prejuicio. Y es **completamente medible**.

La encuesta insiste: "Muestren la métrica. No palabras; números."

Pregunta Incómoda #2: "¿Quién Tiene Documentado el Apetito de Riesgo IA?"

La respuesta típica: "Nuestro CISO conoce el riesgo..."

La pregunta de seguimiento: "¿Está documentado? ¿Lo conoce el Board? ¿Se revisa trimestralmente?"

La respuesta real: "Eh... no exactamente. Es más intuitivo."

¿Por qué es importante? Porque "intuitivo" significa "cuando algo sale mal, buscamos culpables" en lugar de "teníamos un plan consensuado."

La encuesta insiste: "Documenten escalas (Rojo/Amarillo/Verde). Muestren que el Board las aprobó."

Pregunta Incómoda #3: "¿Tienen Pentesting Específico para Ataques IA?"

La respuesta típica: "Bueno, hacemos pentesting general..."

La pregunta de seguimiento: "¿Incluyendo data poisoning, model extraction, adversarial attacks, compromiso CI/CD?"

La respuesta real: "¿Esos son... tipos específicos de ataque IA?"

¿Por qué es importante? Porque los ataques evolucionan. El pentesting de 2015 no detecta attacks de 2026. Si tu penetration test no intenta inyectar datos malignos en tus pipelines de ML, o no simula robo de modelos, entonces estás optimizando defensas anticuadas.

La encuesta insiste: "Contraten especialistas de IA security. El budget de pentesting aumenta 30-50%."

Pregunta Incómoda #4: "¿Qué Porcentaje de Empleados Recibe Capacitación de Seguridad?"

La respuesta típica: "Todos, anualmente."

La pregunta de seguimiento: "¿Y qué porcentaje **realmente completa** y **retiene** el conocimiento? ¿Cómo lo miden más allá de 'completion rate'?"

La respuesta real: "Um... El completion rate es 85%. Click rate en phishing sims es 22%..."

¿Por qué es importante? Porque **1 de 8 empleados hace click en phishing**. Eso significa que incluso con capacitación anual, tienes un 12.5% de brecha conductual. Y eso es **medible y remediable** si lo persigues.

La encuesta insiste: "Implementen micro-learning continuo. Gamifiquen. Hagan coaching personalizado para high-risk users."

ACTO V: POR QUÉ ESTA ENCUESTA NO ES PESIMISTA (INCLUSO CUANDO DUELE)

El Argumento Propositivo

He aquí algo que es fácil olvidar en medio de la avalancha de métricas y compliance: **la encuesta existe porque queremos que mejores.**

No es un stick. Es un espejo con opciones de cambio.

Evidencia:

17.

Niveles claros: Si tienes Nivel 2 en Gobernanza, sabes exactamente qué necesitas para llegar a Nivel 3 (documentar RACI, obtener aprobación Board, establecer cadencia de revisión).

18.

Gaps priorizados: La encuesta te dice no solo "eres malo," sino "estos 3 gaps son críticos y rápidos de remediar; haz estos primero."

19.

Benchmarking: "Estás en Nivel 2.75. Organizaciones líderes en tu sector están en 3.5. Aquí está el gap. Aquí está cómo cerrarlo."

20.

Roadmap concreto: No es "mejora en general." Es "semana 1: documentar RACI. Semana 2: bias audit pilot. Trimestre 2: SIEM upgrade."

21.

Ownership ejecutivo: La encuesta tiene que tener sponsor C-level. No es "proyecto IT." Es "iniciativa estratégica de riesgo."

Niveles claros: Si tienes Nivel 2 en Gobernanza, sabes exactamente qué necesitas para llegar a Nivel 3 (documentar RACI, obtener aprobación Board, establecer cadencia de revisión).

Gaps priorizados: La encuesta te dice no solo "eres malo," sino "estos 3 gaps son críticos y rápidos de remediar; haz estos primero."

Benchmarking: "Estás en Nivel 2.75. Organizaciones líderes en tu sector están en 3.5. Aquí está el gap. Aquí está cómo cerrarlo."

Roadmap concreto: No es "mejora en general." Es "semana 1: documentar RACI. Semana 2: bias audit pilot. Trimestre 2: SIEM upgrade."

Ownership ejecutivo: La encuesta tiene que tener sponsor C-level. No es "proyecto IT." Es "iniciativa estratégica de riesgo."

La Verdad Alegre

La mayoría de organizaciones que hacen esta evaluación con honestidad—aceptando que están en Nivel 2 en varias áreas—**y que luego ejecutan el roadmap**, ven resultados en 9-12 meses:

- Incidentes de seguridad ↓ 40-60% (porque están monitoreando mejor + empleados reportan phishing)
- Compliance gaps cerrados 70-80% (porque tienen documentación y procesos)
- Confianza stakeholder ↑ (porque ven acción, no solo reportes)
- Talent retention ↑ (empleados sienten que la organización toma seguridad en serio)

EPÍLOGO: UNA INVITACIÓN AL DIÁLOGO HONESTO

La encuesta no es una auditoría. Es una **invitación a la conversación seria**.

Sucede así:

Tú (como CISO): "Nuestra madurez es 2.75. Estamos incipientes."

Board (inicialmente confundido): "¿Incipientes? Pensamos que estábamos bien..."

Tú (sonriendo con confianza): "Lo estamos. Pero en ciberseguridad, 'bien' en 2026 significa 'transparencia sobre dónde estamos mal.' Aquí está el plan para mejorar. Aquí está el costo (€280K). Aquí está el timeline (9 meses). Aquí están los riesgos si no hacemos nada (€35M+ en sanciones EU AI Act + breach risk)."

Board (ahora comprometido): "Tiene sentido. ¿Cuándo empezamos?"

Tú (al finalizar): "Pronto. Pero primero, documentemos RACI y formalizamos tu tolerancia de riesgo. Sin eso, todo es castillo de naipes."

LA CONCLUSIÓN: O, POR QUÉ LA ENCUESTA IMPORTA

En un mundo donde:

- Los ataques a supply chain IA están ↑156% (2024 vs 2023)
- La EU AI Act entrará en vigor con sanciones de €35M+
- El 90% de brechas comienzan con phishing (y 1 de 8 empleados hace click)
- La mayoría de organizaciones desconoce cuántos modelos IA tienen

Hacer esta encuesta es decir: "No ignoraré lo que no sé. Miraré al espejo. Documentaré la brecha. Haré un plan. Lo ejecutaré."

Es decir: "La seguridad es una característica, no un hobby."

Es decir: "Queremos liderar, no solo sobrevivir."

La encuesta que hemos construido para usted no es perfecta. Pero es honesta, exhaustiva, y—si la ejecuta con rigor—transformadora.

Ahora, la pregunta es: **¿Qué hará con ella?**

Fin de Narrativa Explicativa

Tono: Irónico, literario, pero profundamente propositivo

Intención: Hacer que la ciberseguridad sea seria sin ser solemne; urgente sin ser apocalíptica

Enero 2026